

Postal address:
Box 8114
104 20 Stockholm
Website:
www.imy.se
Email:
imy@imy.se
Phone:
08-657 61 00
1(11)

CDON AB
Södergatan 22, 6th floor,
211 34 Malmö

Decision after supervision according to the Data Protection Regulation – CDON AB

Swedish Authority for Privacy Protection decision

The Swedish Authority for Privacy Protection (IMY) finds that CDON AB has processed personal data in violation of:

- Articles 5.1(c) and 12.6 of the Data Protection Regulation by requesting additional information from the complainants in complaints 1–3 and 6-7 when they requested to have their personal data deleted, without the processing being necessary to confirm the identity of the complainants.

- Article 12.2 of the Data Protection Regulation by using a burdensome verification method against the complainants in complaints 1–3 and 6-7. The company has thus not sufficiently facilitated the complainants in exercising their right to erasure according to Article 17 of the Data Protection Regulation.

IMY issues a reprimand to CDON AB under Article 58.2(b) of the Data Protection Regulation for violation of Articles 5.1(c), 12.6, and 12.2 of the Data Protection Regulation.

Account of the supervisory case

Processing

IMY has initiated supervision regarding CDON AB (CDON or the company) due to seven complaints. The complaints have been submitted to IMY, in its capacity as the responsible supervisory authority under Article 56 of the Data Protection Regulation. The transfer has occurred from the supervisory authority in the countries where the complainants have submitted their complaints (Finland and Denmark) in accordance with the Regulation's provisions on cooperation in cross-border processing. The processing at IMY has taken place through written correspondence. Given that the complaints concern cross-border processing, IMY has utilized the mechanisms for cooperation and consistency found in Chapter VII of the Data Protection Regulation. The relevant supervisory authorities have been the data protection authorities in Denmark, Norway, and Finland.

1 Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation).

Reference number:

DI-2020-10549

Date:

2023-03-31

Page 1 of 11

Swedish Authority for Privacy Protection

Reference number: DI-2020-10549

2(11)

Date: 2023-03-31

The complaints

Summary of the complaints

In summary, the following is evident from the complaints. The complainants have requested that their personal data be deleted. The company has responded that a request can only be processed if the individual provides their date of birth, address, customer number, information about the most recent purchase such as order number, and information about the payment method including the last four digits of the credit card number for card payments. Several of the complainants argue that their purchases are so far back in time that they cannot recall all the requested information. The complainants question whether all the requested information is necessary to confirm their identity and process their requests.

What the complainants and CDON have stated in their respective complaints

Complaint 1 (Finland with national reference number 2529/182/2018)

The complainant submitted a request for deletion of their personal data on May 28, 2018. The company responded that a request can only be processed if the complainant provides their date of birth, address, customer number, order number, and depending on the payment method for the most recent order, the following information:

- for invoice: price and reference number
- for card payment: the last four digits of the credit card number
- for direct payment: reference number and receipt

The complainant states that they cannot remember or retrieve the information requested by the company because the order was made 5–10 years ago.

Complaint 2 (Finland with national reference number 2537/154/2018)

The complainant submitted a request for deletion of their customer data on May 25, 2018. The company responded that it requires information about the date of birth, customer number, order number, and payment method for the most recent order. The complainant believes it is unreasonable to have to answer these questions to be able to exercise their rights. The complainant no longer has the information requested by the company and used the email associated with the complainant's customer account when requesting deletion.

Complaint 3 (Finland with national reference number 2648/182/2018)

The complainant contacted the Finnish data protection authority on May 31, 2018, after requesting access to and deletion of their data with the company. The company stated on May 29, 2018, in response to the complainant's request, that to verify the complainant as a customer, it needs, for security reasons, the complainant's address, customer number, order number from the most recent order, and depending on the payment method for the most recent order, the following information:

- for invoice: price and reference number
- for card payment: the last four digits of the credit card number
- for direct payment: reference number and receipt

The complainant asserts that it has been a long time since they purchased anything from the company and that they do not have the information that the company requires. Furthermore, it is stated that the company does not seem to delete the data without receiving answers to its detailed questions in a deletion request.

3(11)

Date: 2023-03-31

Complaint 4 (Finland with national case number 2664/182/2018)

The complainant contacted the Finnish Data Protection Authority on May 31, 2018, after requesting deletion from the company. It was 5–10 years ago that the complainant ordered something from the company. To have their data deleted, the complainant needs to provide information from their purchase made several years ago. The complainant also needs to provide personal data that was not previously required to complete a purchase. In its response to the complainant, the company informed that there is a right to access and delete personal data, but that the company has the right to retain certain personal data for accounting purposes. To comply with a request, the company needs, for security reasons, the complainant's date of birth, address, customer number, order number from the most recent order, and depending on the payment method for the most recent order, the following information:

-
- if invoice: price and reference number
-
- if card payment: the last four digits of the credit card number
-
- if direct payment: reference number and receipt

The company has stated that they cannot verify the date the complaint was received by the company or the date the company requested additional information from the complainant. Since the complainant has not been an active customer at CDON for the last two to five years, CDON also confirms that the complainant's personal data has been deleted from CDON's system and that no information about the complainant remains.

Complaint 5 (Finland with national case number 2478/153/2018)

The complainant has contacted the Finnish Data Protection Authority after requesting deletion of their data from the company. The company has informed the complainant that there is a right to access and delete personal data, but that the company has the right to retain certain personal data for accounting purposes. To comply with a request, the company needs, for security reasons, the complainant's date of birth, address, customer number, order number from the most recent order, and depending on the payment method for the most recent order, the following information:

-
- if invoice: price and reference number
-
- if card payment: the last four digits of the credit card number
-
- if direct payment: reference number and receipt

The complainant does not remember when an order was made from the company and how the purchase was paid. It has been over a year since anything was ordered.

The company has stated that they cannot verify the date the complaint was received by the company or the date the company requested additional information from the complainant. Since the complainant has not been an active customer at CDON for the last two to five years, CDON also confirms that the complainant's personal data has been deleted from CDON's system and that no information about the complainant remains.

Complaint 6 (Finland with national case number 2814/154/2018)

The complainant has submitted a complaint to the Finnish Data Protection Authority following a request for deletion from the company on May 21, 2018. The complainant states that the company makes it difficult to exercise the right to deletion by requesting information that should not need to be retained as a customer. The process contributes to the lengthy time it takes to have personal data deleted. In its response to the complainant on May 29, 2018, the company required information about the date of birth, address, customer number, as well as one of the following:

- order number from the most recent order,
- depending on the payment method for the most recent order the following information:

- o if invoice: price and reference number
- o if card payment: the last four digits of the credit card number
- o if direct payment: reference number and receipt

Complaint 7 (Denmark with national diary number 2018-31-0638)

The complainant states that they attempted to delete their customer account online at cdon.dk by using a hyperlink <http://cdon.dk/>. The company responded to the complainant on May 29, 2018, and requested information regarding date of birth, address, customer number, order number from the most recent order, and payment method for the most recent order including the last four digits of the credit card number. The complainant states, among other things, that the company requires more information when exercising the right to deletion than when creating the customer account. The complainant has used the same email address in the request for deletion as when creating the customer account with the company.

What CDON AB has stated otherwise

CDON AB has primarily stated the following.

The Complaints

From the incoming complaints, CDON has been able to identify six out of seven complainants against information in its systems. Regarding these six complainants, CDON notes that it is the data controller for the processing of personal data that the complaints concern. As for the seventh complaint (2478/153/2018), the company has stated that the complainant could not be identified but that it is possible that the complainant has had a customer relationship with CDON under a different email address than the one specified in the complaint sent to the supervisory authority.

In connection with the complainants requesting deletion, they have provided CDON with their name and email address. However, CDON has assessed that these two pieces of information alone are not sufficient to ensure the complainants' identity. CDON has, with support from Article 12.6 of the General Data Protection Regulation, therefore requested supplementary information from all complainants. In addition to name and email address, CDON has requested the following information to ensure the complainants' identity:

- date of birth,
- registered address,
- customer number,
- order number for the most recent order, and
- payment method for the most recent order.

Furthermore, the complainants have needed to provide the following information regarding the payment method:

-

for invoice purchases: price and reference number,

-

for card payments: the last four digits of the card,

-

for direct payments: reference or invoice number.

Existing Procedures

CDON takes the complaints regarding difficulties for registered users to exercise their rights under the General Data Protection Regulation very seriously and has continuously worked to improve its procedures for identification when requests for access to records or deletion are made. Since 2018, when the complaints were received, the identification process has been reviewed and clarified. Over the years, CDON has worked to improve the handling and ensure a simple and secure process when

Page 4 of 11
Swedish Authority for Privacy Protection

Diary Number: DI-2020-10549

5(11)

Date: 2023-03-31

inquiries regarding deletion. Customers who wish to request deletion or access are referred to contact the company at kunddata@cdon.com. In connection with a registered individual contacting the company with a request for deletion, the company informs the registered individual that their email will soon be unsubscribed from CDON's newsletter (if such subscription is activated). To have their account deleted, CDON currently requests that the customer answers two security questions (one from category 1 and one from category 2) so that CDON can ensure that the person reaching out is the correct registrant. The registered individuals may choose to answer one question from each security category provided by CDON. This means that the registered individuals need to answer only one of the following security questions in category 1. According to the control questions in category 1, customers must provide their date of birth, registered address, or customer number at CDON.com. Thereafter, the registered individuals need to answer only one of the following security questions in category 2. The control questions in category 2 are related to the most recent order where the customer either provides the order number or, depending on the payment method, indicates one of the following details: for invoice; amount and OCR number, for card payment: the last four digits of the card, and for direct payment; transaction ID or invoice ID.

In the event that a customer does not wish or is unable to answer the requested security questions, the registered individual is also offered the opportunity to contact customer service for follow-up and investigation of alternative security questions in an attempt to find another way to verify the customer's identity. CDON believes that it is necessary to have at least two additional pieces of information beyond name and email address from customers according to the company's new routine in order to sufficiently verify that it is the correct person making a request. CDON's routine for identifying and verifying the registered individual does not involve collecting new information about the registered individual. CDON only requests to have two different pieces of information verified against the information that CDON already processes about the registered individual with a legal basis to verify the registered individual's identity.

Company's Retention Procedures

CDON has stated that they have a routine for the retention of emails and another routine for the retention of personal data. CDON's routine for the retention of emails means that all emails received in CDON's customer data box, i.e., kunddata@cdon.com, to which customers are referred if they have requests for deletion or data extracts, are retained and deleted after 14 months from the date the emails were received by CDON. Retention of customer profiles at CDON currently occurs based on consumer rights obligations in various countries, for example, after three years in Sweden. CDON thus confirms that all personal data of the complainants has been deleted at CDON.

Justification of Decision

Applicable Provisions

For the processing of personal data to be compliant with the General Data Protection Regulation, it is

required, among other things, that the processing meets the requirements regarding the principles of processing personal data as stated in Article 5 of the General Data Protection Regulation, including the principle of data minimization (Article 5.1 c) and the principle of accountability (Article 5.2).

Since January 22, 2021, CDON only collects birth numbers (if the registered individual chooses to supplement with that information in security question 1) and not the full personal number (diary number DI-2020-10549-18 p.2).

See the Court of Justice of the European Union's judgment in *Valsts ieņēmumu dienests*, C-175/20, EU:C:2022:124, paragraph 50, with the case law cited therein.

Page 5 of 11

Swedish Data Protection Authority

Diary Number: DI-2020-10549

6(11)

Date: 2023-03-31

According to Article 5.1(c) of the General Data Protection Regulation, personal data must be adequate, relevant, and not excessive in relation to the purposes for which they are processed (the principle of data minimization).

In accordance with the accountability principle set out in Article 5.2 of the General Data Protection Regulation, the data controller must be able to demonstrate compliance with paragraph 1 of this article, i.e., bears the burden of proof for this.⁴

According to Article 11.2 of the General Data Protection Regulation, if the data controller, in the cases referred to in paragraph 1 of this article, can demonstrate that they are unable to identify the data subject, the data controller shall, where possible, inform the data subject of this. In such cases, Articles 15–20 shall not apply, except when the data subject provides additional information that makes identification possible for the exercise of their rights under these articles.

According to Article 12.2 of the General Data Protection Regulation, the data controller shall facilitate the exercise of the data subject's rights in accordance with Articles 15–22. In the cases referred to in Article 11.2 of the General Data Protection Regulation, the data controller shall not refuse to comply with the data subject's request to exercise their rights under Articles 15–22, unless the data controller demonstrates that they are unable to identify the data subject.

Article 12.6 of the General Data Protection Regulation states that without prejudice to the application of Article 11 of the General Data Protection Regulation, if the data controller has reasonable doubts about the identity of the individual making a request under Articles 15–21, they may request additional information necessary to confirm the identity of the data subject. In the European Data Protection Board (EDPB) guidelines 01/2022 on the right of access⁵, the following is stated.

If the data controller has reasonable grounds to doubt the identity of the requesting person, they may, as stated above, request additional information to confirm the data subject's identity. However, the data controller must at the same time ensure that they do not collect more personal data than is necessary to enable the identification of the requesting person. Therefore, the data controller should conduct a proportionality assessment, which must take into account the type of personal data being processed (e.g., special categories of data or not), the nature of the request, the context in which the request is made, as well as any harm that could result from improper disclosure. In assessing proportionality, excessive data collection should be avoided while ensuring an adequate level of security in processing.⁶

The data controller should implement an authentication procedure (verification of the data subject's identity) to ensure the identity of individuals requesting access to their data and to ensure the security of the processing of a

⁴ See the Court of Justice of the European Union ruling *Valsts ieņēmumu dienests*, C-175/20, EU:C:2022:124, paragraphs 77 and 81.

⁵ Guidelines 01/2022 on data subject rights - Right of access Version 2.0 Adopted on 28 March 2023 (EDPB Guidelines 01/2022 on the right of access).

⁶ EDPB Guidelines 01/2022, paragraph 70, IMY's translation; original: "As indicated above, if the

controller has reasonable grounds for doubting the identity of the requesting person, it may request additional information to confirm the data subject's identity. However, the controller must at the same time ensure that it does not collect more personal data than is necessary to enable authentication of the requesting person. Therefore, the controller shall carry out a proportionality assessment, which must take into account the type of personal data being processed (e.g. special categories of data or not), the nature of the request, the context within which the request is being made, as well as any damage that could result from improper disclosure. When assessing proportionality, it should be remembered to avoid excessive data collection while ensuring an adequate level of processing security."

Page 6 of 11

Swedish Data Protection Authority

Diary Number: DI-2020-10549

7(11)

Date: 2023-03-31

Request for access in accordance with Article 32, for example, a secure channel for data subjects to provide additional information. The method used for authentication should be relevant, appropriate, proportionate, and respect the principle of data minimization. If the data controller implements measures aimed at identifying the data subject that are burdensome, it must adequately justify this and ensure compliance with all fundamental principles, including data minimization and the obligation to facilitate the exercise of the data subjects' rights (Article 12.2 of the General Data Protection Regulation).

Assessment by the Swedish Data Protection Authority

Complaints

IMY shall, in accordance with Article 57.1 f of the General Data Protection Regulation, handle complaints and, where appropriate, investigate the matter to which the complaint pertains. The case includes seven complaints. IMY has requested that CDON comment on what data the company has requested, the necessity of each individual piece of data, the date when the request for deletion was received in each respective complaint, the date when the company requested additional information to confirm the identity in each respective complaint, and whether the complainants contacted the company after May 25, 2018.

From complaint 4 (Finland with national diary number 2664/182/2018) and complaint 5 (Finland with national diary number 2478/153/2018), no date is indicated for when the complainants made a request for deletion to the company or when the company requested the additional information. The company has stated that it has deleted the complainants' personal data in the two individual complaints in accordance with its routine and cannot verify the date when the request in each respective complaint was received or processed. IMY finds no reason to doubt that CDON has lacked the ability to find any information about the complainants and their requests for deletion. Several years have passed since the complaints were submitted to the Finnish Data Protection Authority.

IMY notes that it is not possible to draw any secure conclusions about what has occurred in the cases of the two complainants based on what has been possible to investigate in the complaints. Among other things, particularly in light of the fact that the complainants' requests relate to the time closely following the application of the General Data Protection Regulation, it has not been possible to investigate whether these two complaints are covered by the General Data Protection Regulation. CDON has further confirmed that no personal data about these two complainants is currently being processed by the company. Against this background, IMY finds that the matter in the two complaints has been investigated to the extent appropriate under Article 57.1 f of the General Data Protection Regulation. IMY therefore finds no reason to further investigate these two complaints. Consequently, IMY has, based on the remaining five relevant complaints in the case, both reviewed the company's actions in these individual cases and assessed whether the company's current routine is compliant with the General Data Protection Regulation.

7 EDPB Guidelines 01/2022, paragraph 71, IMY's translation, original; "The controller should

implement an authentication procedure in order to be certain of the identity of the persons requesting access to their data, and ensure security of the processing throughout the process of handling access requests in accordance with Art. 32 GDPR, including for instance a secure channel for the data subjects to provide additional information. The method used for authentication should be relevant, appropriate, proportionate and respect the data minimization principle. If the controller imposes measures aimed at authenticating the data subject which are burdensome, it needs to adequately justify this and ensure compliance with all fundamental principles, including data minimization and the obligation to facilitate the exercise of data subjects' rights (Art. 12(2) GDPR).

Page 7 of 11

Swedish Data Protection Authority

Diary Number: DI-2020-10549

8(11)

Date: 2023-03-31

****General Principles****

It can be stated that the data controller, in order to identify a data subject, may request additional information that is necessary if the data controller has reasonable grounds to doubt the identity of the person submitting a request. The General Data Protection Regulation does not explicitly regulate which information may be requested or how the additional information should be collected. The data controller must conduct a proportionality assessment to determine what is appropriate in light of the regulation's requirements, including security, but also against the background of the requirement in Article 12.2 of the General Data Protection Regulation, according to which the data controller shall facilitate the exercise of the data subject's rights. Requiring identification information routinely without consideration of whether the information is necessary as described in Article 12.6 of the General Data Protection Regulation is, according to IMY, contrary to both this provision and the principle of data minimization in Article 5.1(c) of the General Data Protection Regulation.

As follows from the wording of these provisions and as confirmed by the EDPB's guideline 01/2022 on the right of access, the data controller must conduct a proportionality assessment and be able to justify the verification method used. To avoid excessive data collection, a request for additional information must be proportional in relation to the type of data being processed and the harm that may arise. This is also confirmed by the guidelines.

****Has there been a violation of the General Data Protection Regulation regarding the complaints raised in this case?****

The question is whether the information that the company has required to meet the requests in the individual cases where the General Data Protection Regulation is applicable (i.e., complaints 1-3 and 6-7) has been necessary to identify the respective complainants and thus in accordance with the General Data Protection Regulation. The information that the company has required in the individual complaints, in addition to name and email, has been date of birth, registered address, customer number, order number, and payment method for the most recent order, as well as, depending on the payment method, price and reference number for invoice payments, the last four digits of the card for card payments, and reference or invoice number for direct payments.

The company has been given the opportunity to justify how each requested piece of information has been necessary to identify the complainants in the individual cases. The company has responded without further explaining the necessity of each requested piece of information, stating that name and email alone have not been sufficient to identify the complainants and verify that the correct person is making a request. According to IMY, the company's account does not provide sufficient support to establish that all of the other relevant information has been necessary to identify the data subjects in accordance with Article 12.6 of the General Data Protection Regulation and the principle of data minimization in Article 5.1(c) of the General Data Protection Regulation. It is CDON, as the data controller, that must be able to demonstrate that the processing is carried out in accordance with the regulation (Article 5.2 of the General Data Protection Regulation). IMY believes that CDON has not done this. IMY thus concludes that CDON AB has processed personal data in violation of Articles 5.1(c) and 12.6 of the General Data Protection Regulation.

In this case, the complainants have had to provide relatively many personal data to be able to exercise their right to erasure, including order number and price for the most recent order as well as reference number for invoice purchases, along with additional information.

8 EDPB's Guidelines 01/2022, General considerations on the assessment of the data subject's request, p. 2-3.

Page 8 of 11

Swedish Data Protection Authority

Diary Number: DI-2020-10549

9(11)

Date: 2023-03-31

information. In some cases, it has been a long time since the complainants made any purchases from CDON. This has meant that the complainants have been unable to exercise their right to erasure under Article 17 of the General Data Protection Regulation without having to make an effort to search for, in some cases, old data and in any case, many pieces of information. By using such a burdensome verification method for erasure requests without justification, the company has not facilitated the exercise of the rights of the data subjects in the manner required by Article 12.2 of the General Data Protection Regulation. CDON AB has thus processed personal data in violation of Article 12.2 of the General Data Protection Regulation.

Is the company's current routine compliant with the General Data Protection Regulation?

The investigation shows that the company has continuously reviewed its routines for handling erasure requests since 2018, when all relevant complaints in the matter were received. The general routines that have been reviewed are those that have been in effect from January 22, 2021, until the date of IMY's decision in the current case.

To ensure the identity of the data subject requesting erasure, the data subject now needs to answer two questions (one question from category 1 and one question from category 2), such as date of birth and order number. In category 1, since January 22, 2021, data subjects do not need to provide their personal identification number but only the date of birth if the data subject chooses to supplement with that information. No new personal data is requested to confirm the identity of the data subject, but rather two different pieces of information to compare against data that the company already processes about the data subject to verify the data subject. That CDON verifies the identity of the data subject before erasing personal data is also a protection for the data subject, who should not have their personal data erased by mistake. The company also offers an alternative route for the data subject who cannot or does not want to answer the security questions, namely to contact customer service to find another way to verify the identity of the data subject. For a customer who has not made an order, there is thus the option to contact customer service instead.

Against this background, IMY finds that CDON's existing routine is not disproportionate and thus not in violation of the General Data Protection Regulation, provided that the company only collects the information specified in the routine in situations where there is reason to doubt the identity of the data subject and that only the information necessary to identify the data subject is requested.

Choice of intervention

Article 58.2 and Article 83.2 of the General Data Protection Regulation state that IMY has the authority to impose administrative fines in accordance with Article 83. Depending on the circumstances of the individual case, administrative fines shall be imposed in addition to or instead of the other measures referred to in Article 58.2 of the General Data Protection Regulation, such as orders and prohibitions. Furthermore, Article 83.2 of the General Data Protection Regulation specifies which factors should be considered when deciding whether administrative fines should be imposed and when determining the amount of the fine. If it concerns a minor infringement, IMY may, as indicated in Recital 148, instead of imposing a fine, issue a reprimand in accordance with Article 58.2 b of the General Data Protection Regulation. Consideration shall be given to aggravating and mitigating circumstances in the case, such as the nature, severity, and duration of the infringement as well as previous relevant infringements.

IMY notes the following relevant circumstances. The current supervision covers CDON AB's handling of five individual complainants' requests in the situation to which the complaints pertain.

Page 10 of 11

Swedish Data Protection Authority

Diary Number: DI-2020-10549

10(11)

Date: 2023-03-31

The company has taken measures to facilitate the exercise of rights by data subjects in accordance with the General Data Protection Regulation and has changed its routines so that they are compliant with the General Data Protection Regulation. Some measures had already been taken before this supervisory case was initiated. Furthermore, the identified infringements occurred relatively long ago. The company has not previously received any corrective action for violations of data protection regulations. Against this background, IMY finds that this is a minor infringement in the sense referred to in Recital 148 and that CDON AB should be given a reprimand in accordance with Article 58.2 b of the General Data Protection Regulation for the identified infringements.

This decision has been made by the unit manager Catharina Fernquist after presentation by the lawyer Salli Fanaei. Catharina Fernquist, 2023-03-31 (This is an electronic signature)

Copy to

Data Protection Officer

Page 11 of 11

Swedish Data Protection Authority

Diary Number: DI-2020-10549

11(11)

Date: 2023-03-31

How to appeal

If you wish to appeal the decision, you should write to the Swedish Data Protection Authority. Indicate in the letter which decision you are appealing and the change you are requesting. The appeal must be received by the Swedish Data Protection Authority no later than three weeks from the day you received notice of the decision. If the appeal has been submitted in a timely manner, the Swedish Data Protection Authority will forward it to the Administrative Court in Stockholm for consideration. You can email the appeal to the Swedish Data Protection Authority if it does not contain any sensitive personal data or information that may be subject to confidentiality. The authority's contact details are provided on the first page of the decision.